

Guest Book

Bối cảnh (Context)

Diễn đàn Hacker Space vừa mở một "Cuốn sổ lưu bút" (Guestbook) công khai. Bất kỳ ai cũng có thể để lại lời chào hoặc thông điệp ẩn danh. Quản trị viên (Admin) của diễn đàn là một người rất nhiệt tình, họ sẽ đăng nhập vào hệ thống và đọc mọi lời nhắn mới cứ mỗi 5 phút một lần.

Nhưng có vẻ như trang web đã quên kiểm tra nội dung lời nhắn. Những người dùng nghịch ngợm bắt đầu gửi những đoạn văn bản chứa thẻ HTML kỳ lạ, khiến giao diện trang web bị xô lệch.

Mục tiêu (Objective)

- **Nhiệm vụ:** Để lại một lời nhắn độc hại trong Guestbook sao cho khi Admin vào đọc lời nhắn, trình duyệt của Admin sẽ tự động gửi Cookie đăng nhập của họ về máy chủ do bạn kiểm soát.
- **Vấn đề / Lỗ hổng:** Ứng dụng dính lỗ hổng **Stored Cross-Site Scripting (Stored XSS)**. Đầu vào từ người dùng (lời nhắn) được lưu thẳng vào cơ sở dữ liệu và hiển thị ra cho mọi người xem mà không trải qua quá trình mã hóa (HTML Entity Encoding).
- **Flag:** Lấy được Cookie của Admin, sử dụng nó để đăng nhập với quyền Admin và lấy Flag.

Gợi ý (Hints)

- Thẻ `<script>` trong HTML có tác dụng gì?
- Làm thế nào để dùng JavaScript đọc được Cookie hiện tại (`document.cookie`) và gửi nó tới một webhook của bạn (như RequestBin hoặc ngrok)?